

Fecha: 21 de Septiembre del 2026

CNO 4: CIBERSEGURIDAD

ACTIVIDAD 8 LAB: FILE PATH TRAVERSAL TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Documentación

Maestro: Servando López Contreras

Alumno: Quetzal Olin Rodríguez Jiménez

Contenido

Objetivo.....	2
Ambiente de laboratorio.....	3
Comandos utilizados	6
Resultados	7
Conclusiones	7

Objetivo

Descripción breve: Documentar el laboratorio *File Path Traversal — Traversal sequences blocked with absolute path bypass* realizado con Burp Suite, mostrando el objetivo del ejercicio, el entorno de laboratorio, los pasos y comandos empleados, los resultados observados y las conclusiones extraídas.

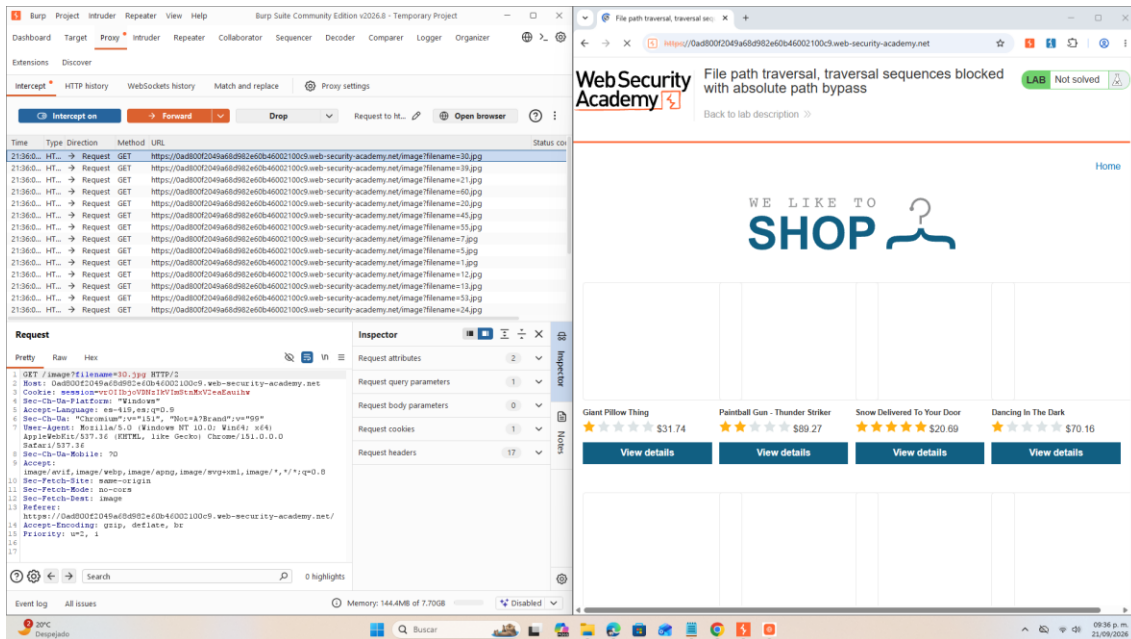
Objetivo específico: Identificar y explotar una vulnerabilidad de *path traversal* donde las secuencias relativas están bloqueadas pero es posible eludir la protección usando rutas absolutas; demostrar la técnica, registrar evidencias y proponer mitigaciones.

Ambiente de laboratorio

Resumen del entorno:

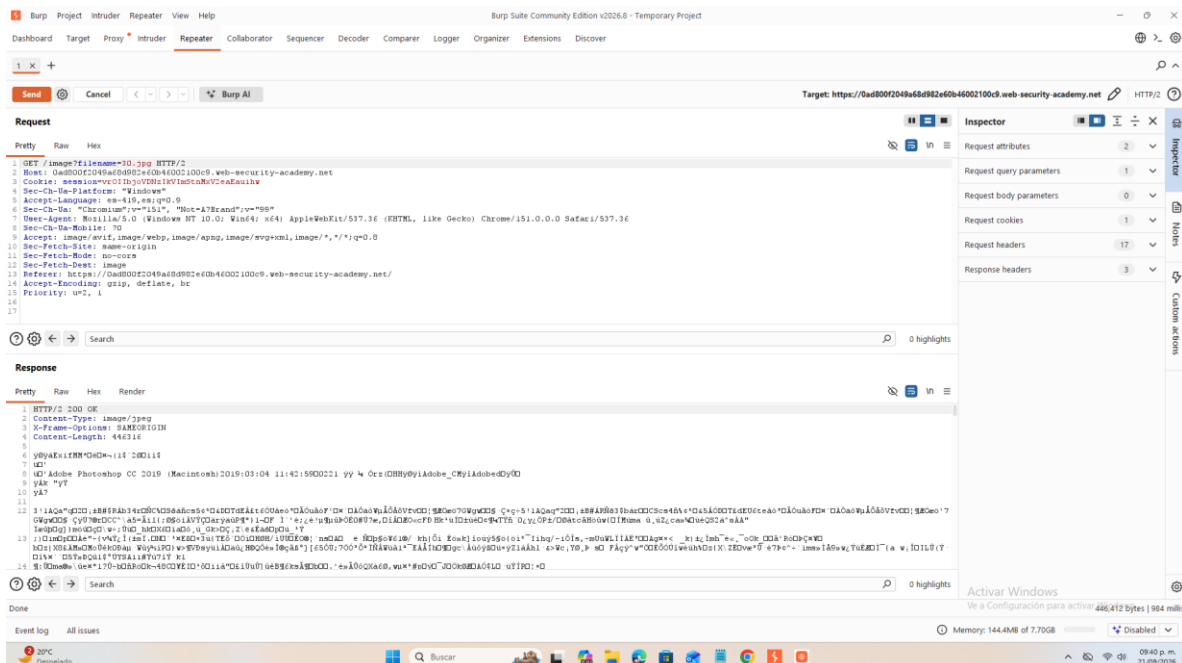
- **Máquina atacante:** Kali Linux (o similar) con Burp Suite Community/Professional instalado.
- **Máquina víctima / aplicación objetivo:** Aplicación web vulnerable desplegada en una VM o contenedor (por ejemplo, una aplicación de prueba en Apache/Nginx que sirve archivos desde un directorio restringido).
- **Red:** Red aislada (NAT/Host-only) para pruebas; tráfico HTTP/HTTPS interceptado por Burp Suite.
- **Herramientas adicionales:** curl, netcat (opcional), navegador configurado para usar el proxy de Burp, editor de texto para preparar payloads.

Imagen 1



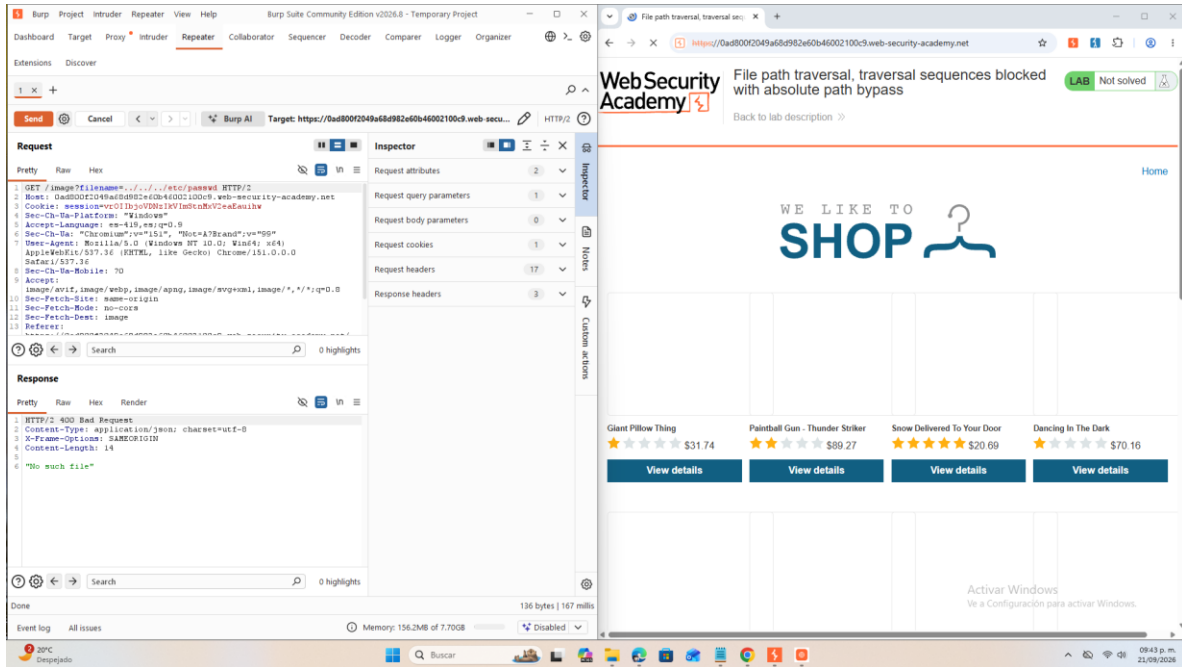
- *Descripción:* Aquí podemos observar la página al iniciarla y las peticiones que suceden (casi totalmente por imagenes para la página).

Imagen 2



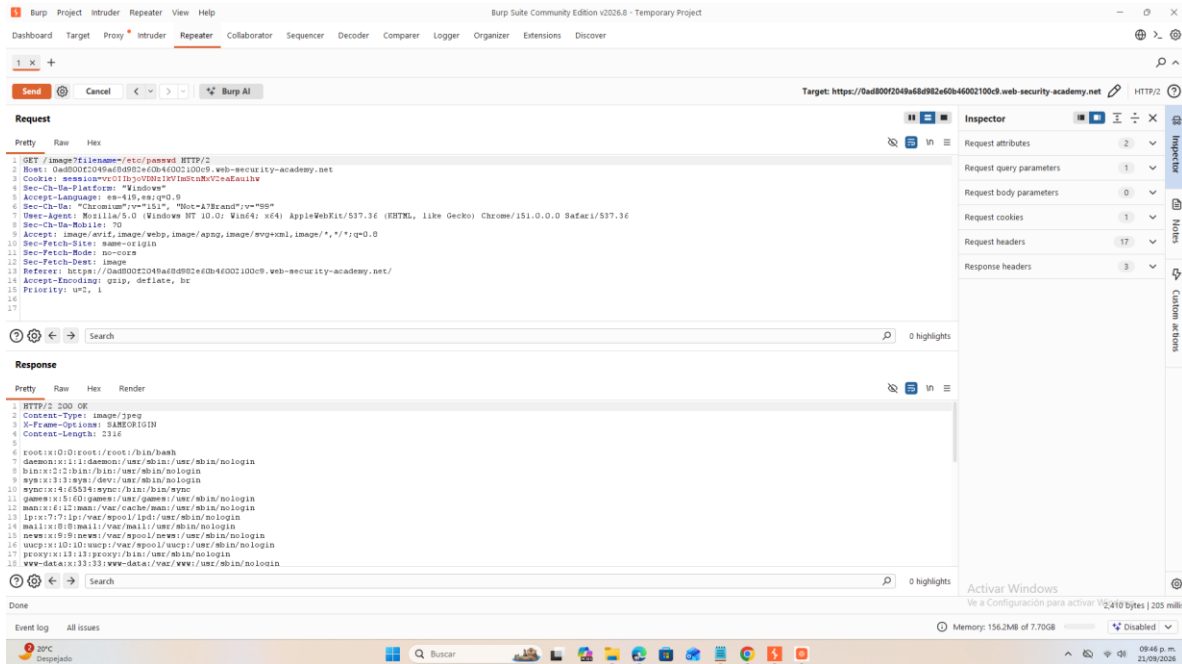
- *Descripción:* Aquí igual que en laboratorio anterior vamos a mandar a repeat una de las imágenes y observamos que nos da una respuesta válida.

Imagen 3



- *Descripción:* Intentamos por el método anterior de regresar en el directorio y buscar acceder a la ruta deseada y observamos un error

Imagen 4



- **Descripción:** Intentamos con una ruta absoluta `/ect/passwd` y observamos que es exitoso y obtenemos acceso al server

Comandos utilizados

Burp Suite – Proxy (Intercept ON): Se activó la opción Intercept on para capturar las peticiones HTTP generadas por el navegador.

Forward: Se utilizó el botón Forward para permitir que la página cargara después de interceptar las solicitudes.

Observación de tráfico GET: Se identificaron múltiples peticiones de tipo GET hacia recursos estáticos.

Prueba de acceso a directorios: Se intentó navegar hacia el directorio raíz regresando niveles (../) para comprobar la estructura de directorios y posibles accesos indebidos.

Resultados

Evidencias y observaciones clave:

- **Bypass exitoso con ruta absoluta:** Se logró leer archivos fuera del directorio permitido usando rutas absolutas cuando las secuencias relativas estaban filtradas.
- **Comportamiento del servidor:** El servidor aceptó la ruta absoluta y devolvió el contenido solicitado; la validación aplicada solo bloqueaba patrones de traversal relativos.
- **Impacto:** Divulgación de información sensible (lectura de archivos del sistema o de configuración) que puede facilitar escalamiento o exfiltración.
- **Capturas adjuntas:** Incluir las imágenes listadas en la sección *Ambiente de laboratorio* como evidencia visual del proceso y del resultado.

Conclusiones

Resumen y recomendaciones:

- **Causa raíz:** Validación insuficiente de rutas; bloqueo de patrones relativos sin normalizar o restringir rutas absolutas.
- **Riesgo:** Alto para confidencialidad de datos; un atacante puede acceder a archivos sensibles si el servidor no restringe correctamente la resolución de rutas.
- **Mitigaciones recomendadas:**
 - **Normalizar rutas** en el servidor antes de cualquier validación (resolver .., enlaces simbólicos y rutas absolutas).
 - **Restringir el acceso** a un directorio raíz (chroot-like) o usar listas blancas de archivos permitidos.

- **Validar y sanitizar** entradas del usuario; rechazar rutas que comiencen con / si la aplicación no las necesita.
- **Registrar y alertar** accesos anómalos a rutas fuera del directorio esperado.